



Internal Risk Assessment Policy – Operational Risk



Document Owner:

ibex Compliance & Risk
Management

ComplianceLeadership@ibex.co

This document may not be duplicated, reproduced or distributed without the express written consent



Document Information

Document #:	CO-REG-04
Document Title:	CO-REG-04 Internal Risk Assessment Policy – Operational Risk V7.0
Documentation Classification	INTERNAL (I)
Applicable Standard(s) / Framework(s):	ISO 31000 &27005
Document Status:	Final
Approved By:	Sandra Fernandez Signed by: <i>Sandra Fernandez</i> 2F30A2AF686E4D6...
Date Approved:	04/30/2025
Date of Effectiveness	05/01/2025
Reference Document(s):	

Table of Contents

1.	PURPOSE.....	1
2.	SCOPE	1
3.	DEFINITIONS	1
4.	ROLES AND RESPONSIBILITIES	2
5.	POLICY	3
5.1.	GENERAL PROVISIONS	3
5.2.	ASSESSING SECURITY RISKS	3
5.3.	TYPES OF ASSESSMENTS	4
6.1.	RISK ASSESMENTS	4
6.2.	CONTROL RISK LIKELIHOOD	5
6.3.	IMPACT / SEVERITY	5
6.4.	OVER-ALL CONTROL RISK RATING.....	5
7.1.	CONTROL RISK LEVELS AND QUALIFICATION DEFINITION	6
7.2.	CONTROL RISK LEVELS.....	7
8.	RISK TREATMENT	7
9.	RISK COMMUNICATION AND CONSULTATION	8
10.	CALL COMPLIANCE VIOLATIONS – CORRECTIVE ACTIONS OVERSIGHT / ACCOUNTABILITY	8
11.	REMEDIATION.....	8
12.	ENFORCEMENT	9
13.	REVISION HISTORY	9

1. Purpose

This document aims to set the criteria of how risks are identified, who is responsible for risk ownership, how risks impact the confidentiality, integrity, and availability of information, and establish the actions required to manage risk from asset and risk identification to risk remediation. The policy ensures that the risks in ibex are properly managed until they become acceptable to the threshold set by the management.

2. Scope

The standard mentioned in this document shall be implemented across all departments and campaigns under ibex.

3. Definitions

Term	Definition
Client	A company that ibex conducts business for or on behalf of.
CIA	Confidentiality, Integrity, and Availability (CIA). The CIA is a model that organizations use to evaluate their risks and controls. - Confidentiality – measures to protect information from unauthorized access - Integrity – measures to protect information from alteration; provides an assurance in the accuracy and completeness of data - Availability – measures to protect timely and uninterrupted access to the system. Information must be available to authorized users.
Contractual Agreement	Legal document created that captures the agreement activities and/or services provided by ibex to the client. Detailed requirements and pricing are usually specific in these types of documents, along with many other terms and conditions.
Site & Internal Risk Assessment	An assessment conducted to monitor a program's operational adherence to company controls, contractual requirements and regulations/governance and ensures it meets our internal standards.
System Risk Assessment	An assessment that tests a program's system adherence to IT security controls.
Overall Risk Rating	A rating assigned after the assessment indicating the relative compliance associated with laws/governance and client standards and requirements.
Program	The specific project worked by ibex on behalf of the represented client.

4. Roles and Responsibilities

Role	Responsibilities
Compliance and Risk Management Team	Shall monitor the compliance with system security standards, contractual requirements and regulatory governance.
Customer Security Team	Shall conduct call compliance monitoring to ensure client requirements are met and/or regulatory adherence and early detection of fraud and/or suspicious activity.
Compliance Analyst	Shall perform the risk assessment exercise undertaken with the Asset Owner. The Compliance Analyst must ensure that the exercise is conducted under these conditions: • During onboarding of campaigns; • Request for additional system tool and access and; • Annual risk assessment exercise as required by the different standards and regulations.
Compliance Manager	Shall be responsible for assessment oversight. Presents the reviewed assessment to the VP Compliance & Risk Management for approval and distribution.
SVP Compliance & Risk Management	Shall be responsible for the overall implementation of this policy. Shall be the final approver of assessments and shall reports trends, risks, and mitigation plans to the executive group.
Department Head/Asset Owner	Responsible for enforcing the mitigating controls to ensure that the identified risks are properly managed until it becomes acceptable to the department's risk appetite. The department head or the asset owner must also be responsible for the following: • Partnering with the Compliance and Risk team to continually strengthen ibex's risk management framework and risk culture by ensuring there are robust processes in place to identify, communicate, and manage material risks across the organization. • Communicating risks concerning their area of operations or whenever there is a change request in their systems and processes. • Promoting risk management awareness via education to management and staff as required.
IT Security	Shall provide additional technical inputs when performing risk assessments. Shall recommend controls to identified risks and shall also approve implementation of systems, tools, and accesses.
Client Services	Shall be responsible in scoping the business justification, securing the documented approval for any change request, and communicating the observations and recommendations in the risk assessment reports.

5. Policy

5.1. General Provisions

- 5.1.1. The risk to the company's information asset and information processing facility whether internal or external must be properly managed to ensure that the company assets are protected and secured.
- 5.1.2. Risk Assessments should be used as a tool to ensure that ibex can respond to the best of its abilities to changing demands, improve its performance and make most effective use of its resources. ibex also aspires to achieve business excellence and become the business partner of choice by taking calculated risks, which have been identified and evaluated.
- 5.1.3. Risk Assessments are an integral part of ibex's business planning and decision-making. All strategic and operational risks must be identified as part of the departmental operational plans. For new initiatives and projects, risk assessments must be used to inform the department leaders risk associated with project and/or recommended mitigation needed to be applied.
- 5.1.4. ibex management shall identify the department head/asset owners for each department or campaign who shall be active participants in the risk assessment as mandated by this policy.
- 5.1.5. A Risk and Asset Register shall be established to record strategic and operational risks and the potential business impact posed by various tools or applications being used by a department or campaign of ibex. As part of the register, the threats to CIA of information and the classification and evaluation of the risk must be recorded, together with the risk treatment plan and the monitoring mechanism.
- 5.1.6. All identified risks shall have a nominated person who shall be responsible for implementing the proposed treatment and action, as well as monitoring and managing that risk.
- 5.1.7. In line with ISO 31000 Risk Management Standard a documented communication and consultation must be present between ibex and client stakeholders in order to support the framework and facilitate the effective application of risk management.
- 5.1.8. In line with ISO 27001, the risk assessment controls are mapped out accordingly based off the standard's clauses and ibex's defined statement of applicability.

5.2. Assessing Security Risks

- 5.2.1. ibex must conduct risk assessments to identify, quantify and prioritize risks against criteria to obtain risk acceptance and achieve the objectives relevant to the company. The results shall be used to guide and determine the appropriate management actions, priorities for managing information security risks and for implementing controls selected to protect the information, systems, and company assets against these risks.

- 5.2.2. The systems and internal risk assessment shall be conducted in all departments and campaigns of ibex and should include relationships with risk assessments in other areas if appropriate.
- 5.2.3. Risk assessments shall be undertaken in a methodical manner capable of producing comparable and reproducible results.
- 5.2.4. Risk assessments shall be performed periodically to address changes in the security requirements and in the risk situation, e.g. in the assets, threats, vulnerabilities, impacts, the risk evaluation, and when significant changes occur. This must ensure that the management has reliable and detailed information about the risk that allows us to create appropriate control and to achieve information security.
- 5.2.5. Risk management shall apply to all departments of ibex. The systems and internal risk assessment must be conducted in the following conditions.
 - 5.2.5.1. Risk assessments must be conducted annually and inclusive of all departments supporting ibex in compliance to standard industry requirements such as ISO27001, PCI DSS version 3.2, GDPR, HIPAA, and SOC.
 - 5.2.5.2. Onboarding - system risk assessments must be conducted upon onboarding of a new campaign or line of business in which the Compliance and Risk Management Team must participate during IT discovery of the Project Management team in which application tools and other requirements are discussed with the client.
 - 5.2.5.3. Request for additional application tool and access that are outside of the campaign / department's standard operating environment.

5.3. Types of Assessments

- 5.3.1. Site & Internal Risk Assessment monitors program's operational adherence to company controls, contractual requirements and regulations/governance and ensures it meets our internal standards.
- 5.3.2. System Risk Assessment tests a program's system adherence to IT standards to ensure customer data are protected.
- 5.3.3. Call Compliance reviews to ensure account is meeting all client requirements and/or regulatory adherence and early detection of fraud and/or suspicious activity.

6. System Risk Assessment and Results Rating

6.1. Risk Assessments

Risk Assessments require a reasonable inquiry into a program's ability to meet the controls and requirements for the proposed risk assessment.

6.2. Control Risk Likelihood

The charts below identify the control risk likelihood and the qualification definition for the internal assessments:

Low	The level of dependency and complexity of the services is low and easily support the level of transaction processing. The volume of activities does not expose the company to any significant risk. The event / risk may have occurred on a single or very few instances in the past or may re-occur but at a very limited instance.
Moderate	The services effectively support the level of transaction processing. The volume of activities exposes the company to some risk. The event / risk may have occurred on several occasions in the past, is still occurring, or may re-occur but at a moderate number of instances.
High	The level of dependency and complexity of the services and state or type of exposure to sensitive data adds a significant risk to the business. The event / risk may have occurred on multiple occasions, is still occurring, or may re-occur at any given time.

6.3. Impact / Severity

Insignificant	Very little or NO effect to Operations and / or the over-all business (financial impact – to factor)
Minor	Can be absorbed as normal operations
Moderate	Operations and / or the business may be affected
Major	Operations and / or the business may be adversely affected
Catastrophic	May severely affect Operations and / or the over-all business

6.4. Over-all Control Risk Rating

If the Risk Average is between:	Overall Risk Rating
16.191 and higher	High
7.638 and 16.190	Moderate
1.000 and 7.637	Low

7. Internal Risk Assessment and Results Rating

7.1. Control Risk Levels and Qualification Definition

The charts below identify the control risk level and the qualification definition for the internal assessments:

Control Risk Level	Qualification Definition
Met	The control observed/monitored fulfilled the expectation, standard and/or requirement
Observation	- A one-off instance that has no impact to security/client data system - Documented process in place but not consistently being followed
Low	- Process in place being followed but not documented - Previous Observation rating was identified in the last assessment and the same finding has been observed
Moderate	- No process exists, and/or documented process is not compliant with standards and regulation (No Security Risks) - Previous Low rating was identified in the last assessment and the same finding has been observed
High	- Any time Security control is marked as a 'Fail' - Any control non-compliant with the contractual requirements - Any control where customer data has a risk of being exposed externally - Previous Medium rating was identified in the last assessment and the same finding has been observed

7.2. Control Risk Levels

Control Risk Level	1 - 5 Findings	6 - 9 Findings	10+ Findings
Observation	Satisfactory	Satisfactory	Satisfactory
Low	Satisfactory	Satisfactory	Need Improvement
Moderate	Satisfactory	Need Improvement	Needs Improvement
High	Needs Improvement	Unsatisfactory	Unsatisfactory

8. Risk Treatment

- 8.1. Compliance and Risk Management Team determines the treatment and level of action plan for each risk level.
- 8.2. Compliance will provide an outline of the approach to be used to action the risk. Any interdependencies with other risks should also be highlighted.
- 8.3. Compliance and Risk Management Team presents the risks, risk action plans, and recommended controls to ibex Management.

Action Plan Levels	Definition
Reduce	Implement a strategy that is designed to reduce the likelihood or consequence of the risk to an acceptable level, where elimination may be excessive in terms of time or expense.
Avoid	Decide not to proceed with the activity that introduced the unacceptable risk, choosing an alternative more acceptable activity that meets business objectives, or choosing an alternative less risky approach or process
Accept	Make an informed decision that the risk rating is at an acceptable level or that the cost of the treatment outweighs the benefit. This action plan may also be relevant in situations where a residual risk remains after other action plans have been put in place. No further action is taken to treat the risk, however, ongoing monitoring is recommended and with consideration of existing policies, goals, and business objectives.
Transfer	Transfer the risk to another party. This may be used in combination with other risk action plans.

9. Risk Communication and Consultation

- 9.1. Effective communication is essential to the information security risk management process. It ensures that those responsible for implementing risk management understand the basis on which decisions are made, and why certain actions are required. Communication and consultation about risk facilitates agreement between decision makers and other key stakeholders on how to manage risk. Risk communication activity should be performed continually.
- 9.2. A Summary Finding Report is supplied to ibex Management. The report will contain the following:
 - 9.2.1. A summary of the control categories that were audited
 - 9.2.2. A summary of the control risk levels received
 - 9.2.3. A final overall rating of the assessment
 - 9.2.4. The detailed findings, the potential risk associated, risk action plans, and recommendations for any control marked with an Observational risk or higher.

10. Call Compliance Violations – Corrective Actions Oversight / Accountability

- 10.1. As a result of any call compliance investigation, the Customer Security Team will collaborate with Operations and Human Resource departments and will provide full results.
- 10.2. Customer Security team will use as a guideline formal corrective action referenced in the Employee Code of Conduct.
- 10.3. Where employee requires further review and/or to be placed on a corrective action, Customer Security will require Human Resource to provide details of the employee's discipline status.

11. Remediation

- 11.1. Owners of identified gaps will be required to participate and close out remediation items with evidence demonstrating that the gap identified has been mitigated.
- 11.2. Should owners choose to accept the risk and not mitigate an identified gap, they will be required to provide Senior Leadership approval as evidence of risk acceptance.
- 11.3. The Remediation Chart below is a guideline for the expected period to close out findings. The Compliance and Risk Management Team recommends all findings identified to be closed in 30 days or less but understands may take longer*.

Control Risk Level	Remediation Finding Completion Guideline
Met	N/A

Observation	40 days or less
Low	35 days or less
Moderate	30 days or less
High	15 days or less

* ibex reserves the right to extend the completion period based on business need.

12. Enforcement

All policies or versions of previously created policies developed after the date of effectiveness of this policy shall adhere to this policy.

13. Revision History

Version	Date	Details of Changes	Change By	Reviewed By	Approved By
1.2	12/3/2019	Creation	Kristen McGuire	Sandra Fernandez	Sandra Fernandez
1.2	7/1/2020	Created IRS version	Sandra Fernandez	Sandra Fernandez	Sandra Fernandez
2.0	10/25/2020	Refined the Purpose, Scope, some of the Roles and Responsibilities, Policy provisions, and minor format changes	Flara Jaculina	Sandra Fernandez	Sandra Fernandez
3.0	03/11/2021	Risk Action Plans	Flara Jaculina	Sandra Fernandez	Sandra Fernandez
4.0	11/5/2021	Updated Remediation Timelines	Flara Jaculina	Sandra Fernandez	Sandra Fernandez
5.0	07/19/2022	Added provisions to comply with ISO27001 recommendations and updated the risk indicator rating scale	Flara Jaculina	Sandra Fernandez	Jim Ferrato – CIO, Sandra Fernandez – VP Compliance
6.0	02/27/2023	Added provisions to comply with ISO27005 - CIA / Updated the System Risk Assessment Control Rating Scale	Flara Jaculina	Sandra Fernandez	Jim Ferrato – CIO, Sandra Fernandez – VP Compliance
6.1	04/01/2024	Reviewed / No Changes	Flara Jaculina	Sandra Fernandez	Jim Ferrato Sandra Fernandez

Version	Date	Details of Changes	Change By	Reviewed By	Approved By
7.0	04/01/2025	Transferred to New Template	Lloyd Macatangay	Flara Jaculina	Sandra Fernandez